Rapport du 13 novembre 2026

# Rapport d'avancement

Fusion Leap AI Growth : plateforme SaaS multi-tenant de croissance (CRM, canaux, campagnes, agents IA). Les fondations, le CRM (projets, contacts, leads, deals, capture, import) et le socle des canaux e-mail (intégrations, webhooks, conversations, envoi sous contrôles, statuts et réception, désabonnement) sont en place ; le désabonnement est en revue. Jours **J0 à J34** réalisés sur 68.




**35 / 68**
jours réalisés

**7 559**
tests automatisés, tous verts

**20 / 33**
modules terminés

**40 / 41**
PR fusionnées
(1 en revue)

**12 / 14**
décisions d'architecture (ADR)
acceptées

**29**
failles trouvées par les revues adverses, toutes corrigées

DEPUIS LE 12 NOV. **+3 point** d'avancement +2 jour +155 test

FUSION

### 40 PR fusionnées

Tout le travail de J0 à J34 est dans la branche principale, un commit par sujet.

ENVOI SOUS CONTRÔLES

### 15 contrôles avant chaque e-mail

Approbation humaine obligatoire, puis contrôle final juste avant l'appel au fournisseur.

RÉCEPTION SÛRE

### Aucun contact créé par un inconnu

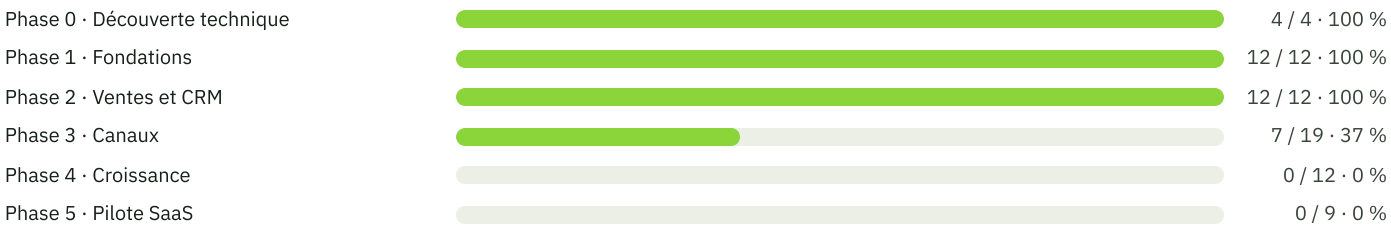
Une réponse est rattachée à la bonne conversation ; un expéditeur inconnu ou usurpé va dans une file de tri.

### En une phrase

Les phases 0 à 2 sont terminées et fusionnées ; la phase 3 (canaux) est bien engagée : un e-mail ne part qu'avec une approbation humaine et un contrôle final dans le worker, les statuts du fournisseur et les réponses sont rattachés sans jamais créer de contact. Chaque e-mail porte maintenant un lien de désabonnement signé. Rien ne peut encore partir pour de vrai : il manque l'écran contacts et consentement (J30b), l'activation d'un canal et le compte d'essai du fournisseur (checkpoint C3).

## Avancement par phase

jours réalisés



# Journal du jour

13 novembre 2026

Le travail du jour raconté étape par étape : ce qui a été fait, les vérifications menées et le volume de code touché.

J'ai ajouté en base la fonction qui active une intégration (réservée au serveur) et les codes d'erreur de validation.

Migration et retour arrière écrits · Tests pgTAP lancés · **+68 −0**

J'ai écrit l'adaptateur de webhook WhatsApp (signature, compte, déduplication), la poignée de main de Meta et le client de validation de l'API Graph.

Cas de Meta rejoués sur des fixtures · **+315 −1**

J'ai ajouté la route de vérification de connexion, la poignée de main GET et l'écran « Connecter un numéro WhatsApp » en trois langues.

Écran branché sur les routes · **+511 −5**

J'ai écrit les tests pgTAP et d'acceptation HTTP, puis fait attaquer le tout par une revue de sécurité indépendante.

Suite complète lancée · Failles corrigées avec un test · **+293 −6**

J'ai documenté l'API, le runbook de configuration Meta, la note de l'ADR 007, le journal et le CHANGELOG.

Documentation mise à jour · **+88 −0**

# Feuille de route

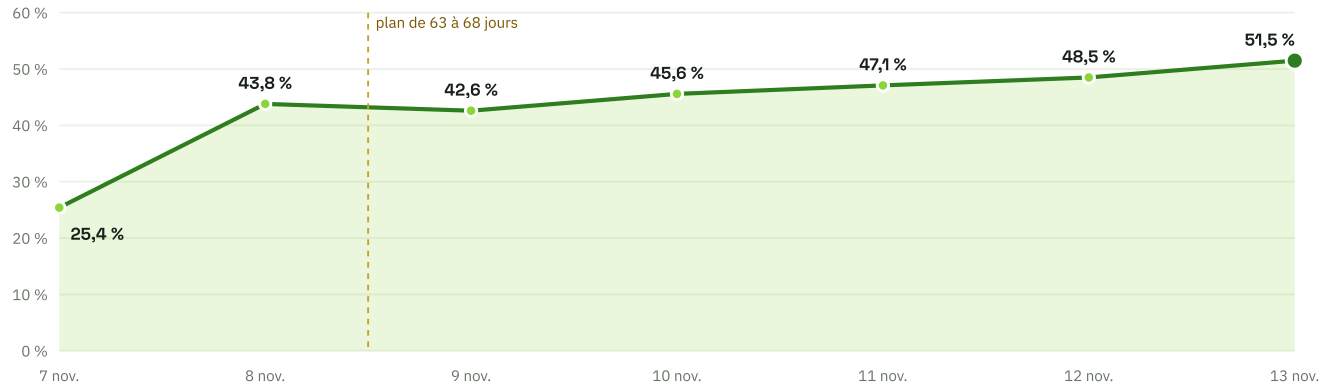
jalons, courbe d'avancement, phases

Les jalons sont des portes de qualité : on ne les franchit qu'avec les preuves.

| | | |
|---|---|---|
| **G1 · Isolation** | J15 | Isolation de deux entreprises démontrée |
| **G2 · Parcours CRM** | J27 | Lead jusqu'au deal gagné, avec historique |
| **C2 · Écrans CRM** | 9 nov. 2026 | Option A : écrans avant G3 |
| **C3 · Compte d'essai e-mail** | avant tout envoi réel | Fournisseur confirmé sur un compte d'essai |
| **G3 · Canaux** | 18 janv. 2027 | Boîte unifiée, envoi et réception sûrs |
| **Fin du pilote** | 16 févr. 2027 | Phase 5 : pilote avec un client |

## Avancement global au fil des jours

Part des 68 jours du plan réalisés, mesurée à chaque rapport.




### Phase 0 · Découverte technique — 100%

4 / 4 jours · 4 modules
2 faits · 2 à valider

### Phase 1 · Fondations — 100%

12 / 12 jours · 12 modules
12 faits

### Phase 2 · Ventes et CRM — 100%

12 / 12 jours · 5 modules
5 faits

### Phase 3 · Canaux — 37%

7 / 19 jours · 6 modules
1 fait · 3 à faire

### Phase 4 · Croissance — 0%

0 / 12 jours · 3 modules
3 à faire

### Phase 5 · Pilote SaaS — 0%

0 / 9 jours · 3 modules
3 à faire

**33 jours**
restent à réaliser sur 68 (48,5 % du plan)

**18 janv. 2027**
prochain jalon daté : G3 · Canaux

**J33**
prochaine journée : désabonnement, prérequis du premier envoi marketing

## Phase 0 — Découverte technique 4 jours 100 %

| JOUR | MODULE | AVANCEMENT | STATUT | LIVRABLE |
|---|---|---|---|---|
| J0 | Analyse de la spec | 100 % | Fait | Lacunes, questions, plan validé. |
| J1 | ADR et modèle de données | 100 % | À valider | Décisions d'architecture (ADR) et modèle de données rédigés. |
| J2 | Intégrations et flux | 100 % | Fait | WhatsApp, Salla, e-mail, CRM. |
| J3 | Menaces, tests, backlog | 100 % | À valider | 53 menaces STRIDE, plan de tests et backlog. |

## Phase 1 — Fondations 12 jours 100 %

| JOUR | MODULE | AVANCEMENT | STATUT | LIVRABLE |
|---|---|---|---|---|
| J4 | Monorepo et CI | 100 % | Fait | pnpm + Turborepo, CI GitHub (2 jobs). |
| J5 | Environnements et secrets | 100 % | Fait | Validation zod, garde-fou anti-fuite. |
| J6 | Noyau multi-tenant (base) | 100 % | Fait | Organisations, membres, plans, abonnements. |
| J7 | RLS et harnais de test | 100 % | Fait | Politiques par opération, tests via l'API. |
| J8 | Authentification bilingue | 100 % | Fait | Supabase SSR, sessions, redirections sûres. |
| J9 | Organisations et contexte actif | 100 % | Fait | Création atomique, sélecteur d'organisation. |
| J10 | Membres, invitations, RBAC | 100 % | Fait | Matrice ADR 014, jetons hachés. |
| J11 | Couche service | 100 % | Fait | Idempotence, limitation de débit, erreurs. |
| J12 | Audit et journaux | 100 % | Fait | Audit en lecture seule, journal JSON. |
| J13 | Jobs et worker | 100 % | Fait | File Postgres, claim, bail, dead letter. |
| J14 | Plans et quotas | 100 % | Fait | Quotas atomiques, Platform Admin, écran d'administration. |
| J15 | Jalon G1 : isolation | 100 % | Fait | Jalon G1 : T1 et T5 automatisés, audit C1. |

## Réalisé en plus du plan demandes du propriétaire du produit

| MODULE | AVANCEMENT | STATUT | CONTENU |
|---|---|---|---|
| Français par défaut (fr / ar / en) | 100 % | Fait | Locale française par défaut, arabe (RTL) et anglais ; PR n°5. |
| Refonte UI (Tailwind + shadcn) | 100 % | Fait | Coque d'application, thème clair/sombre, accessibilité ; PR n°7. |
| E-mails locaux (Mailtrap) | 100 % | Fait | Bac à sable SMTP ; mot de passe à saisir dans supabase/.env. |
| Paramétrage : palette de couleurs | 100 % | Fait | Couleurs claires et sombres, aperçu, contraste AA ; PR n°9. |
| Paramétrage : logo | 100 % | Fait | PNG, JPEG, WebP ≤ 128 Ko, SVG refusé ; PR n°9. |
| Rapport d'avancement automatisé | 100 % | Fait | Généré à chaque commit : pnpm report:progress. |
| Guide de démarrage pour un nouveau développeur | 100 % | Fait | start-fusion-lead-ai-growth.md : prérequis, installation, comptes de test, tests. |
| Paramétrage : serveur SMTP (Mailtrap) | 100 % | Fait | Mot de passe chiffré (AES-256-GCM), test d'envoi, administrateurs de la plateforme. |
| Guide de tests des phases 2 et 3 (PDF) | 100 % | Fait | 107 cas (interface et technique), fiche de résultats, données de démonstration et outil d'appel de l'API. |
| Refonte du rapport d'avancement | 100 % | Fait | 7 pages : synthèse, feuille de route, détail par phase, livré récemment, qualité, décisions ; historique et comparaison avec le rapport précédent. |

## Phase 2 — Ventes et CRM 12 jours 100 %

| JOUR | MODULE | AVANCEMENT | STATUT | LIVRABLE |
|---|---|---|---|---|
| J16–J17 | Projets et produits | 100 % | Fait | J16 base, quotas, API ; J17 écran complet et fichiers (stockage privé, liens signés). |
| J18–J20 | Contacts, leads, deals, activités | 100 % | Fait | J18 contacts et consentement, J19 pipelines, leads et deals, J20 activités et chronologie. |
| J21–J23 | Capture publique, assignation, import CSV | 100 % | Fait | J21 formulaire public (clé, anti-abus), J22 assignation automatique et alertes, J23 import CSV avec aperçu et rapport. |
| J24–J26 | Écrans CRM, adaptateur, tests de vente | 100 % | Fait | J24 écrans leads, deals et export audité, J25 adaptateur CRM (fichier), J26 tests des rôles de vente. |
| J27 | Parcours complet · Jalon G2 | 100 % | Fait | Parcours lead jusqu'au deal gagné avec historique ; checkpoint C2 : écrans CRM planifiés avant G3. |

## Phase 3 — Canaux 19 jours 37 %

| JOUR | MODULE | AVANCEMENT | STATUT | LIVRABLE |
|---|---|---|---|---|
| J28–J30 | Intégrations et secrets | 100 % | Fait | J28 intégrations et secrets chiffrés, J29 pipeline des webhooks, J30 conversations et messages. |
| J31–J33 | Envoi, statuts et réception e-mail · désabonnement | 100 % | En revue | J31 envoi sous contrôles, J32 statuts du fournisseur et réponses, J33 désabonnement (lien signé, page publique, révocation). |
| J34–J37 | WhatsApp Cloud API | 25 % | En revue | J34 connexion et webhook signé fait (fixtures, aucun compte Meta) ; J35 réception, J36 envoi, J37 boîte de réception à faire. |
| J38–J41 | Inbox unifiée · Gate G3 | 0 % | À faire | Envoi, réception, arrêt sûrs |
| J30b–J30d | Écrans CRM : contacts et fiche lead (décision C2) | 0 % | À faire | Avant le premier envoi (contacts) et avant la boîte de réception (fiche lead) |
| J39b–J39c | Écrans CRM : configuration et import (décision C2) | 0 % | À faire | Clés de formulaire, règles d'assignation, notifications, import ; avant G3 |

## Phase 4 — Croissance 12 jours 0 %

| JOUR | MODULE | AVANCEMENT | STATUT | JALON / REMARQUE |
|---|---|---|---|---|
| J42–J46 | Campagnes, segments, approbation, UTM | 0 % | À faire | |
| J47–J50 | Agents IA (brouillons validés par un humain) | 0 % | À faire | |
| J51–J53 | Tableau de bord · Gate G4 | 0 % | À faire | Campagne auditable |

## Phase 5 — Pilote SaaS 9 jours 0 %

| JOUR | MODULE | AVANCEMENT | STATUT | JALON / REMARQUE |
|---|---|---|---|---|
| J54–J55 | Onboarding, Salla (mode marketing) | 0 % | À faire | |
| J56–J59 | Console admin, durcissement, staging | 0 % | À faire | |
| J60–J62 | Recette · Gate G5 | 0 % | À faire | 10 critères d'acceptation |

# Livré récemment

J30 à J34 : les canaux e-mail et WhatsApp

Chaque journée est validée par des tests, puis attaquée par une revue de sécurité indépendante avant la fusion.

## J30 Conversations et messages

- Un fil par contact et canal ; un message ne peut pas porter une autre entreprise que son fil.
- Lecture par rôle : le commercial ne lit que ses conversations.

Preuves : 126 tests de base, 12 tests API · Revue de sécurité : 0 bloquant 2 majeurs 5 moyens

## J31 Envoi d’e-mail sous contrôles

- Approbation humaine obligatoire, contrôle final juste avant l'appel dans le worker.
- Au plus un envoi par message ; « accepté » n'est pas « livré ».

Preuves : 94 tests de base, 10 tests API, 30 tests worker · Revue de sécurité : 0 bloquant 2 majeurs 5 moyens

## J32 Statuts et réception d’e-mail

- Livré, rebond dur (adresse supprimée) et plainte (adresse supprimée et « ne plus contacter »).
- Une réponse est rattachée à la bonne conversation ; un expéditeur inconnu ou usurpé va dans une file de tri, jamais dans un contact.

Preuves : 114 tests de base, 9 tests API, acceptation HTTP réelle · Revue de sécurité : 1 bloquant 1 majeur 5 moyens

## J33 Désabonnement

- Chaque e-mail porte un lien signé (sans donnée personnelle), les en-têtes de désabonnement en un clic et un pied de page ; sans clé de signature, rien ne part.
- Le lien ouvre une page de confirmation (jamais de désabonnement à l'ouverture) : consentements e-mail révoqués, adresse supprimée, envois en file annulés avec leurs jobs.

Preuves : 42 tests de base, 8 tests d'acceptation HTTP réelle, adaptateurs et web · Revue de sécurité : 0 bloquant 1 majeur 3 moyens

## J34 Connexion WhatsApp

- Un numéro WhatsApp se connecte depuis l'écran Intégrations ; le serveur essaie le jeton auprès de Meta avant de déclarer l'intégration active.
- Les événements de Meta sont reçus avec une signature vérifiée ; une signature fausse ou un numéro inconnu reçoivent le même refus.

Preuves : 30 tests de base, 9 tests d'acceptation HTTP réelle, adaptateurs et web (aucun compte Meta réel) · Revue de sécurité : 0 bloquant 0 majeur 4 moyens

### Déjà possible

- Connecter une intégration e-mail, avec secrets chiffrés et jamais renvoyés.
- Préparer un envoi : approbation humaine, 15 contrôles juste avant l'appel.
- Recevoir les statuts du fournisseur et les réponses, rattachés à la bonne conversation.
- Se désabonner par un lien signé : consentement révoqué, adresse supprimée, envois en attente annulés.
- Connecter un numéro WhatsApp et recevoir des événements signés de Meta (essayé sur des fixtures, pas sur un compte réel).

### Pas encore possible

- Envoyer ou recevoir un vrai e-mail : il manque l'activation d'un canal et un compte d'essai (C3).
- Se réabonner : aucune action pour lever une désinscription (écran contacts, J30b).
- Gérer les contacts et le consentement à l'écran (J30b) et lire les conversations (boîte de réception, J37).
- WhatsApp (J34 à J37) : en attente du compte Meta.

# Qualité mesurée

tests automatisés, tous verts

7 559 tests au total (+155 test depuis le 12 nov.).

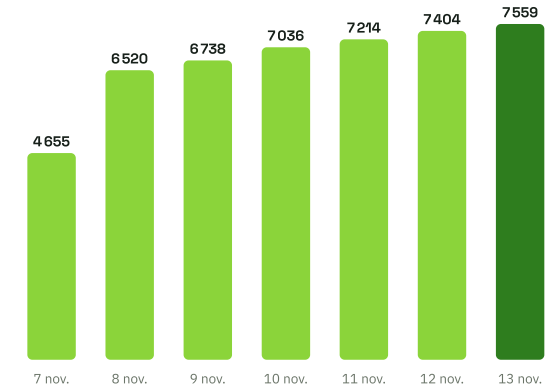
### Tests par catégorie

Ce que couvre chaque ligne.

| | | |
|---|---|---|
| Web (application)<br>Écrans, routes HTTP et services de l'application | | 2 560 |
| Base de données (pgTAP)<br>Tables, droits et règles de la base de données | | 3 000 |
| Permissions (RBAC)<br>Qui a le droit de faire quoi, rôle par rôle | | 394 |
| Domaine (règles métier)<br>Règles métier pures (contrôles d'envoi, consentement…) | | 656 |
| RLS via l'API réelle<br>Isolation entre entreprises, vérifiée par la vraie API | | 485 |
| Worker et adaptateurs<br>Tâches de fond et adaptateurs de fournisseurs | | 261 |
| Acceptation (T1, T5)<br>Parcours complets en HTTP réel sur l'application construite | | 203 |

### Tests au fil des jours

Total à chaque rapport.




### Contrôles automatiques

Lint, typecheck, tests unitaires, base de données (pgTAP), isolation par l'API réelle (RLS), acceptation en HTTP réel, build de production et recherche de fuites de secrets dans le bundle navigateur : tous verts. La CI GitHub exécute trois jobs à chaque PR.

### Sécurité

Chaque journée passe une revue adverse indépendante (attaques réelles contre la base locale, lecture critique du code) puis une re-vérification : isolation entre organisations, journal d'audit non modifiable, secrets chiffrés et jamais renvoyés, aucun contenu de message dans les journaux. Les failles trouvées sont corrigées avant la fusion ; aucune faille exploitable ouverte connue.

# Revues de sécurité adverses

failles trouvées avant la fusion

| JOUR | SUJET | RÉSULTAT |
|---|---|---|
| **J30** | **Conversations et messages** | 0 bloquant · 2 majeurs · 5 moyens |
| **J31** | **Envoi d'e-mail sous contrôles** | 0 bloquant · 2 majeurs · 5 moyens |
| **J32** | **Statuts et réception d'e-mail** | 1 bloquant · 1 majeur · 5 moyens |
| **J33** | **Désabonnement** | 0 bloquant · 1 majeur · 3 moyens |
| **J34** | **Connexion WhatsApp** | 0 bloquant · 0 majeur · 4 moyens |

Toutes ces failles sont corrigées avant la fusion, avec un test qui la reproduit. Un bloquant empêche la fusion ; un majeur est corrigé le jour même.

# Points ouverts et décisions à prendre

À traiter par la responsable technique, le propriétaire du produit ou l'équipe.

| # | POINT | QUI | ÉCHÉANCE |
|---|---|---|---|
| 1 | Réponse à Q2 (propriétaire du domaine d'envoi) et ouverture d'un compte d'essai Postmark : tout ce qui dépend du fournisseur est une hypothèse à confirmer (en-têtes des e-mails entrants, métadonnées des événements, codes de rebond). | Responsable technique | Avant C3 |
| 2 | Aucun flux n'active encore un canal ou une intégration e-mail : sans lui, ni envoi ni réception réels. | Équipe | Avant C3 |
| 3 | Écran contacts et consentement (J30b), avec la levée d'une désinscription : prérequis d'un premier envoi marketing. | Équipe | Avant le premier envoi |
| 4 | Q1 (API du CRM Fusion Leap) et Q5 (marché, région) : toujours sans réponse. | Responsable technique | Avant J34 |
| 5 | Compte développeur Meta bloqué (« compte trop récent ») : WhatsApp est critique pour J34. | Propriétaire du produit | Avant J34 |
| 6 | Choisir le fournisseur IA (ADR 012) et l'hébergeur (ADR 010). | Responsable technique | Avant J47 / J58 |
| 7 | Effacement d'un contact qui a des messages (droit à l'effacement) : procédure d'anonymisation à définir. | Responsable technique | Avant le pilote |
| 8 | Purge des contenus conservés (événements de webhook, file de tri) et rétention du journal d'audit : sinon croissance sans limite. | Équipe | J39 / J57 |
| 9 | Paramétrage de la palette et du logo : réservé aux administrateurs de la plateforme avant de vrais clients (condition de l'ADR 016). | Équipe | Avant J54 |
| 10 | Protection de la branche principale non activée sur GitHub ; un test de base de données (conversations) a échoué deux fois sans cause trouvée. | Responsable technique | À surveiller |
| 11 | Rotation de clé : le trousseau de production n'a qu'une clé ; une rotation casserait les anciens liens de désabonnement et le déchiffrement des anciens secrets. Décider d'une variable des clés précédentes. | Responsable technique | Avant la première rotation |
| 12 | Numéro WhatsApp réservable par une intégration jamais validée, et variable serveur WHATSAPP_VERIFY_TOKEN : valider ces deux choix avant la production. | Responsable technique | Avant C3 |

# Prochaines étapes

| QUAND | ACTION |
|---|---|
| **Maintenant** | Recette des phases 2 et 3 avec le guide de tests (PDF), par une personne qui n'a pas écrit le code. |
| **J30b à J30d** | Écrans contacts et consentement (avant le premier envoi), puis fiche lead (avant la boîte de réception). |
| **J34 à J37** | WhatsApp Cloud API et boîte de réception : dépend du compte Meta. |
| **J38 à J41** | Envoi et réception sûrs sur la boîte unifiée, jalon G3 le 18 janvier 2027. |

### Comment lire ce rapport

Avancement d'un module = part de ses livrables terminés et vérifiés : **100 %** = code, tests et documentation livrés. Statuts : Fait fusionné · En revue PR ouverte · À valider fait mais à valider · À faire à faire. Avancement global = jours réalisés sur 68 (35 ÷ 68 = 51,5 %). Rapport régénéré à chaque commit ( `pnpm report:progress` , branche `day-34-whatsapp-connect` ). Sources : `docs/progress/journal.md` , `docs/plan/development-plan.md` , `scripts/progress-report/data.json` , `scripts/progress-report/history.json` .